

ERP_RMI_SOFULL — Ready-to-Execute Task List (Option A & B)

Generated: 2026-01-07 22:56:54
Scope: RBAC/permission enforcement + security hardening + UAT

Option	Total Tasks	Total Estimasi (jam)	Catatan
Option A (Incremental)	12	85	Paling aman: patch per modul/file, rollback mudah.
Option B (Batch)	6	54	Paling cepat: automation/batch, butuh regression lebih besar.

Option A — Incremental / Per-Module (Recommended for minimal downtime)

Tujuan: patch bertahap, rollback mudah, risiko produksi paling rendah.

ID	Workstream	Task & Detail	PIC	Est (h)	Order	Deliverable	Verifikasi	Rollback
A01	Foundation	Lock baseline RBAC mapping (Dept+Level → Permission) + enforcement map per file Freeze baseline mapping (Lampiran B) as source-of-truth. Create/validate enforcement mapping URL/File → Permission for PURCHASES, MASTER, KPI, DASHBOARD, TOOLS. Decide deny-by-default rules & admin bypass.	Dev + Owner	4	1	Baseline mapping doc (xlsx tab) + enforcement_map.php (or MD) ready to apply; sign-off Owner/ITC.	Review session with Owner: sample 10 URLs vs expected permission.	N/A (planning only)
A02	Purchases	Create purchases/_purchases_bootstrap.php (single gate) + helpers Add module bootstrap: require _shared/bootstrap.php; require_login(); provide purchases_pdo(); purchases_rbac_require(); purchases_require_dept_or_admin(); JSON-safe deny for API endpoints; centralize common includes.	Dev	3	2	New file purchases/_purchases_bootstrap.php + README snippet; lint OK.	php -l purchases/_purchases_bootstrap.php; open purchases/purchases_dashboard.php after temporary include.	Remove bootstrap file; revert requires.
A03	Purchases	Enforce server-side guard on Purchases endpoints (23 files) - phase 1 Add 2 lines on top of each purchases/*.php: require _purchases_bootstrap.php + purchases_rbac_require(per-file perm). Start with most sensitive: purchases_payment_ap.php, purchases_invoice_ap*.php, purchases_import_control_*.php, purchases_forwarder_*.php, purchases_ceisa_pib*.php.	Dev	10	3	Direct URL as unauthorized role returns 302 login or 403; no blank pages. Updated files committed/backed up.	UAT 10 cases: staff SALES denied AP pages; FIN staff allowed edit; FIN manager allowed approve; ACT allowed CEISA.	Restore per-file from backup folder (_backup/...).
A04	Purchases	Upload hardening for 9 Purchases upload pages For each file with \$_FILES: enforce rmi_safe_filename(); use rmi_safe_code() for folder; allowlist ext (pdf/jpg/png/xlsx/csv); max size (e.g., 50MB); realpath prefix check; reject invalid. Ensure delete actions validate object-level authorization.	Dev	8	4	No path traversal; invalid ext/size rejected; uploads stored under /uploads/purchases/<safe_code>; audit entries (if enabled).	Try upload filename './evil.php' (should sanitize + reject ext). Upload pdf OK. Delete doc denied for unauthorized dept.	Restore affected files + remove new upload dirs created during test.
A05	Purchases	CSRF for Purchases critical POST actions Add CSRF token to forms: DP/Final payment, approve actions, upload/delete docs. Verify token on POST; on fail return 403 with message. Backward-compat: allow turning off via config flag for emergency.	Dev	6	5	CSRF token generated per session; POST without token denied; no UX break.	POST replay without token denied; valid token passes; multi-tab works.	Disable CSRF via config flag; revert form changes if needed.
A06	Master	Master upload hardening (11 pages) + object-level auth for docs Identify master pages with uploads (manufactures docs, product media, etc). Apply rmi_safe_filename/safe_code + allowlist + size + realpath. Enforce MASTER.DOC_UPLOAD/DELETE permissions and ownership rules (dept PQP/SCM + admin bypass).	Dev	12	6	Uploads safe; delete guarded; unauthorized access denied server-side.	Staff non-owner dept cannot upload/delete; admin can; view works.	Restore files from backup; keep uploaded files but lock access.
A07	Master	Standardize output escaping (rmi_h) + fix unguarded h() redeclare In master module files flagged 'h()' unguarded', wrap legacy h() defs with function_exists guard; replace risky echoes with rmi_h(). Prioritize pages exposed to many roles.	Dev	8	7	No 'Cannot redeclare h()'; reduced XSS surface; pages render same.	Run php -l; spot test with special chars in input (e.g., <script>) renders escaped.	Restore files from backup.

ID	Workstream	Task & Detail	PIC	Est (h)	Order	Deliverable	Verifikasi	Rollback
A08	KPI	KPI access control enforcement (VIEW/EDIT/ADMIN) + guard endpoints Add require_login + rbac_require: KPI.VIEW for manager+/admin; KPI.EDIT/KPI.ADMIN for HRL/admin. Ensure JSON endpoints deny-by-default; hide menu remains UX only.	Dev	6	8	Staff cannot access KPI pages or JSON; managers can view; HRL/admin can edit.	Test 3 roles: staff denied, manager view ok, HRL edit ok.	Restore KPI files; temporarily restrict via .htaccess if needed.
A09	Dashboards	Dashboard server-side RBAC + data scope (dept/office) Add require_login + rbac_require for each dashboard page. Ensure queries scope by office_code/role where applicable (avoid data leakage). Ensure cache key includes user role/dept (if caching).	Dev	6	9	No dashboard accessible without permission; owner/exec only for exec view.	Direct URL tests across roles; check no cross-office data leakage.	Restore dashboard files; disable dashboard links temporarily.
A10	Tools/Security	Lock down TOOLS.RUN pages (fin_gl_auto.php, stock_update_from_gr.php) Make tools CLI-only OR admin-only with explicit deny for web. Add guard: if php_sapi_name()!='cli' then require admin+csrf. Log executions with request_id and username.	Dev + DevOps	4	10	Tools cannot be triggered by regular users; only admin/cli.	Attempt open via browser as staff → 403; run via CLI works (if allowed).	Restore old tool files; keep tools inaccessible via web (rename).
A11	Audit/Observability	Implement structured audit logging for critical events (no new table by default) Add audit_log() helper writing JSON lines to /logs/audit_YYYYMMDD.log with masking. Events: RBAC change, AP payment, PO approve, upload/delete docs, stock adjustment. Optionally switch to DB table if compliance requires.	Dev	6	11	Audit file logs created; events recorded consistently.	Perform 3 actions and confirm log lines written with username/role/entity.	Disable audit logging flag; remove log writer; keep existing logs archived.
A12	UAT/Go-Live	UAT matrix + anti-privilege escalation tests (horizontal & vertical) Run test matrix per dept (WQS/FIN/SCM/PQP/SALES/HRL/ACT). Include direct URL tests, API tests, upload negative tests, approval flow tests. Capture evidence screenshots and sign-off.	Ops + Dev	12	12	UAT checklist completed + sign-off; issues logged with severity & fix plan.	All critical tests pass; no unauthorized access; no upload bypass.	If SEV1 found, rollback affected module files and re-test.

Option B — Batch / Automation (Fastest)

Tujuan: perubahan cepat via tool; wajib regression checklist lengkap karena perubahan massal.

ID	Workstream	Task & Detail	PIC	Est (h)	Order	Deliverable	Verifikasi	Rollback
B01	Automation	Build auto-inject tool for RBAC enforcement + upload hardening Create CLI tool (tools/rbac_enforce_apply.php) that: reads enforcement mapping, injects bootstrap+rbac_require lines into entypoints, adds safe_filename/safe_code patterns for upload, supports --dry-run, creates timestamped backup.	Dev	8	1	Tool runs on dev; produces change report; backups created.	Dry-run matches expected diff; apply then php -l sample files.	Tool always creates backup; restore from backup folder.
B02	Automation	Prepare enforcement mapping file (machine-readable) for Purchases/Master/KPI/Dashboards/Tools Create tools/enforcement_map.json (or php array) mapping file→permission and file→dept fallback. Include exceptions (public assets, include-only files).	Dev + Owner	4	2	enforcement_map ready; reviewed and approved.	Spot-check 20 files mapping correctness.	N/A
B03	Batch Apply	Run tool on purchases/ (batch) + hotfix exceptions Execute tool apply for purchases. Fix any parse errors or unique file structures manually. Ensure 9 upload pages hardened.	Dev	10	3	Purchases module fully guarded & uploads hardened in one batch.	Direct URL deny tests + payment flow smoke test.	Restore purchases from backup folder.
B04	Batch Apply	Run tool on master/ and sales/ (batch) + hotfix exceptions Apply tool for master and sales modules. Ensure no h() redeclare; add rmi_h replacements where pattern can do safely. Harden uploads.	Dev	12	4	Master/Sales guarded; upload hardening applied; minimal manual fixes.	Smoke test 15 URLs; upload negative tests.	Restore master/sales from backups.
B05	Batch Apply	Run tool on kpi/ dashboards/ tools/ (batch) + deny-by-default Apply tool; enforce KPI view/edit; dashboards view perms; tools cli-only/admin. Ensure API endpoints return 401/403 properly.	Dev	6	5	Sensitive read endpoints closed; dashboards scoped.	Role-based access tests; attempt bypass via direct URL.	Restore folders from backups.
B06	UAT/Go-Live	Full regression + UAT after batch Run full regression checklist >=20 cases: login redirect, deny-by-default, approve gates, upload safety, API read safety, CSRF (if enabled).	Ops + Dev	14	6	Regression report + sign-off.	All SEV1/SEV2 resolved; audit scan improved significantly.	Rollback whole module folders if critical failures.